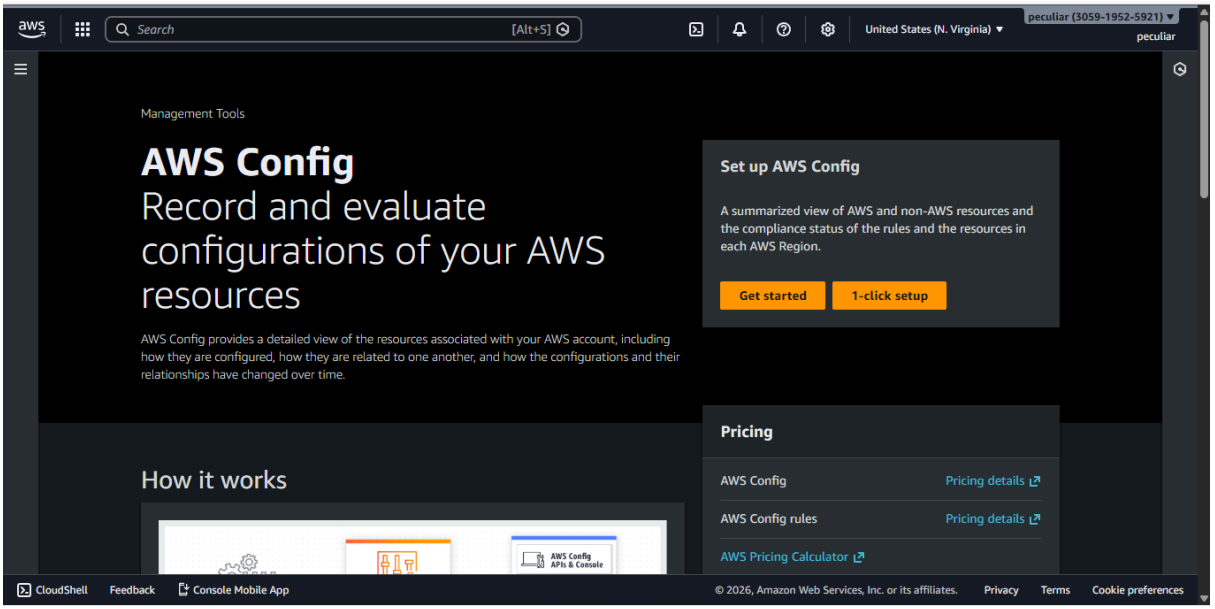
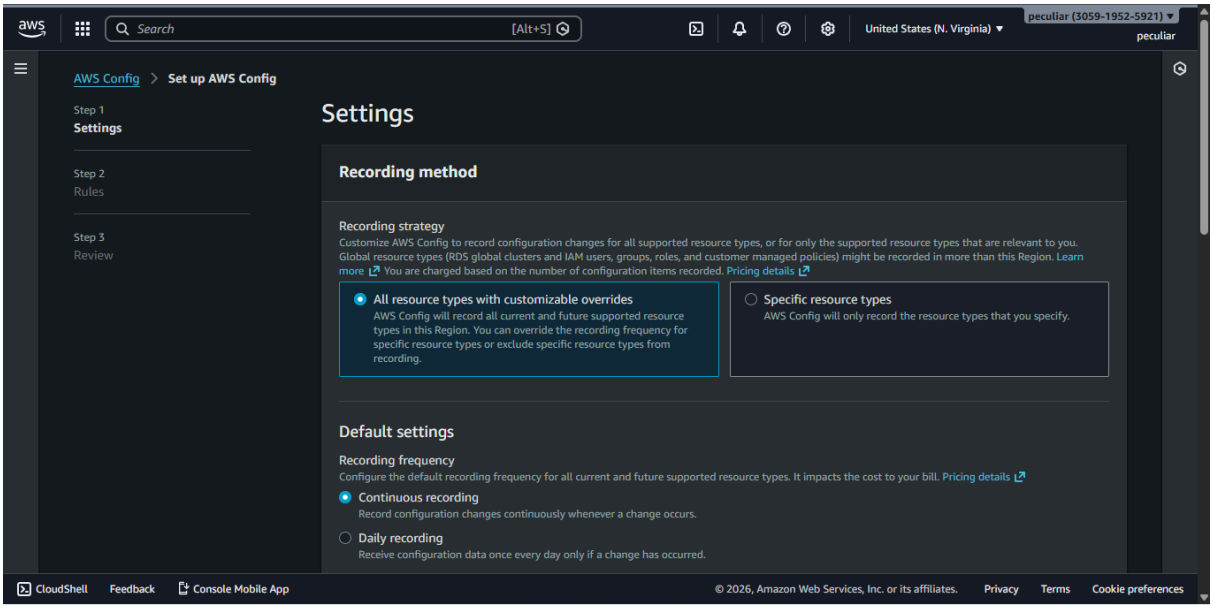
AWS CONTINOUS COMPLIANCE AND CHANGE MANAGEMENT

Part 1: Set up AWS Config (The Recorder)

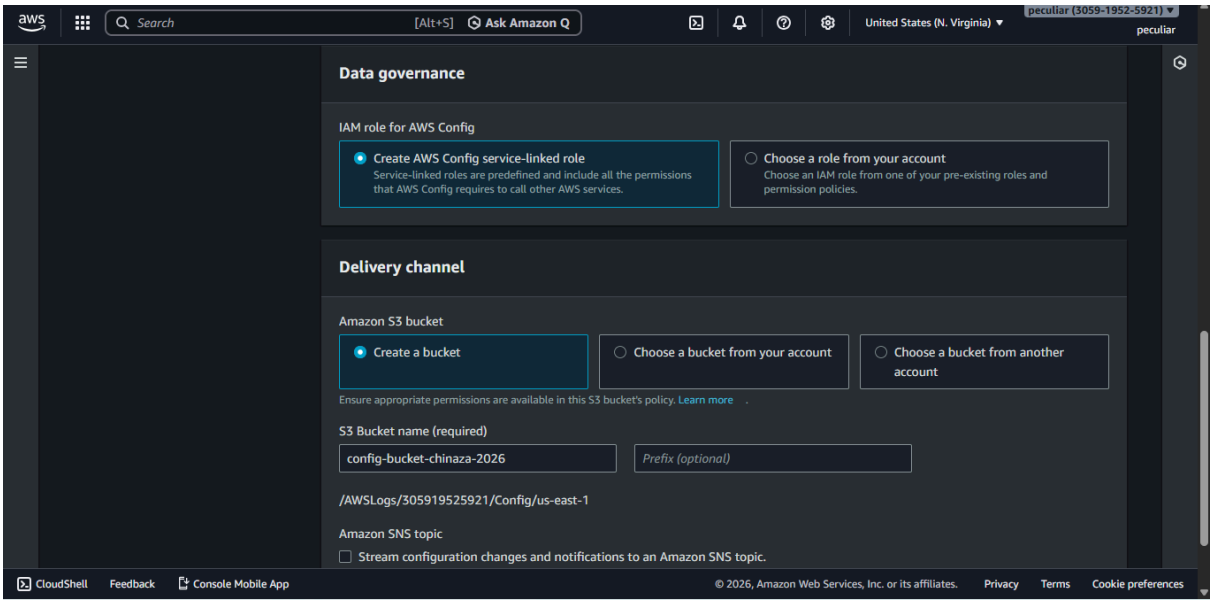
1. Go to the AWS Management Console and navigate to AWS Config. Click Get started or Settings.



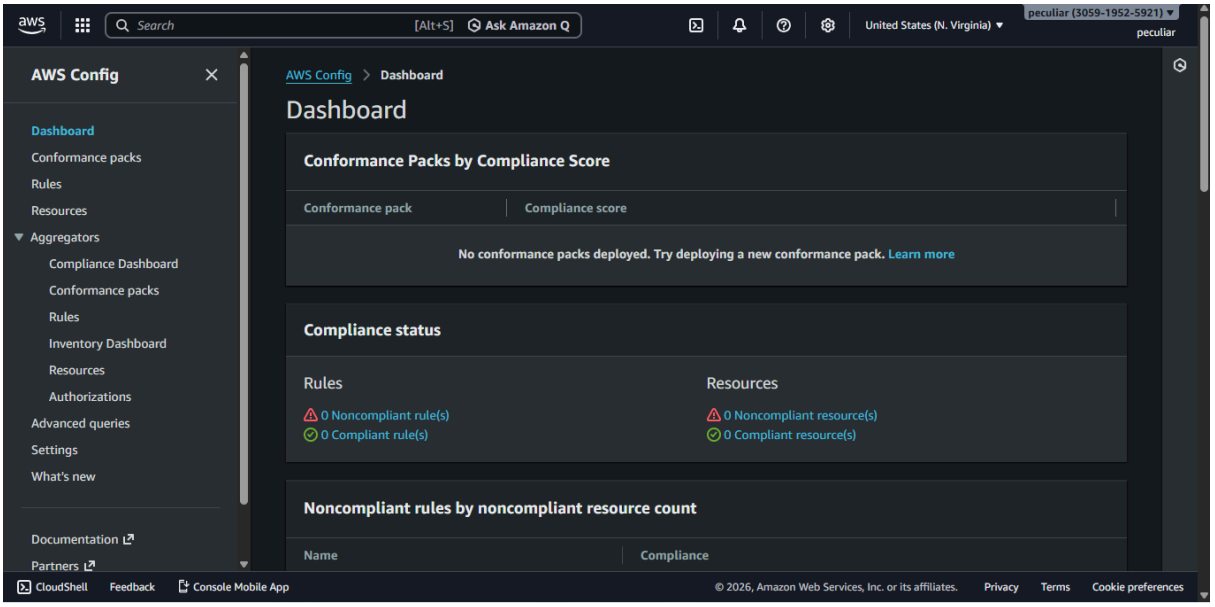
2. Define Recording Scope
   Recording strategy: Choose "Record all resources supported in this region."



3. Set up Permissions
   For the Data governance: Select "Create AWS config service-linked role"
   To Set up Data Delivery (The Delivery Channel):
   Choose "Create a new bucket" and give it a unique name
   ”config-bucket-chinaza-2026”
   Skip the SNS Topic for now.



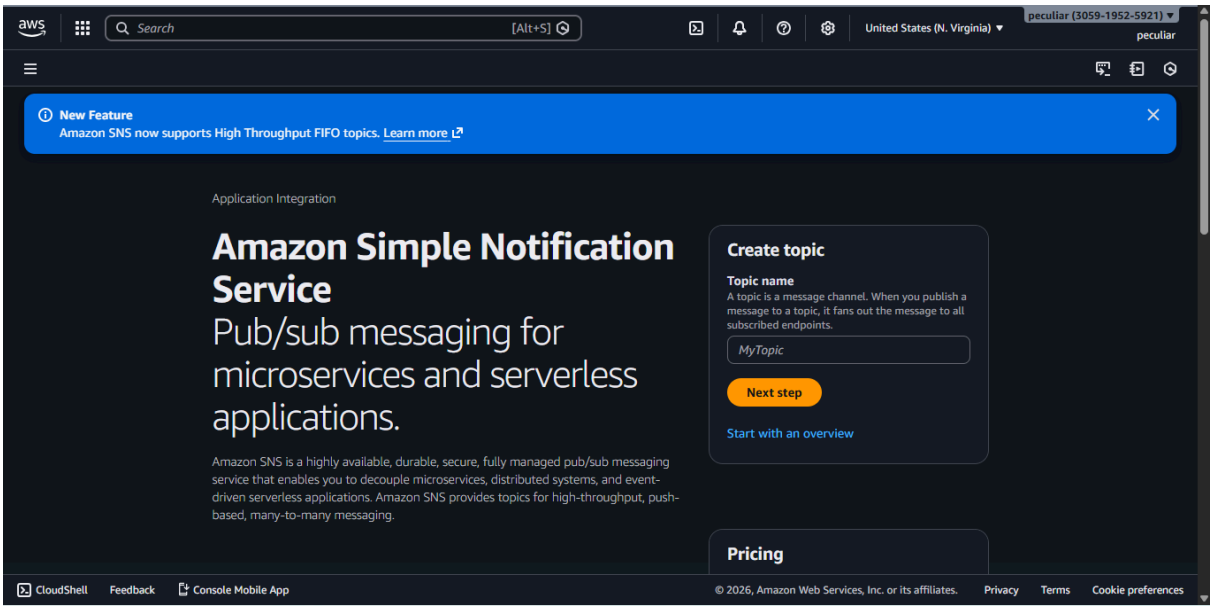
4. Review and Confirm the settings to enable AWS Config.



Part 2: Set up AWS SNS (The Messenger)

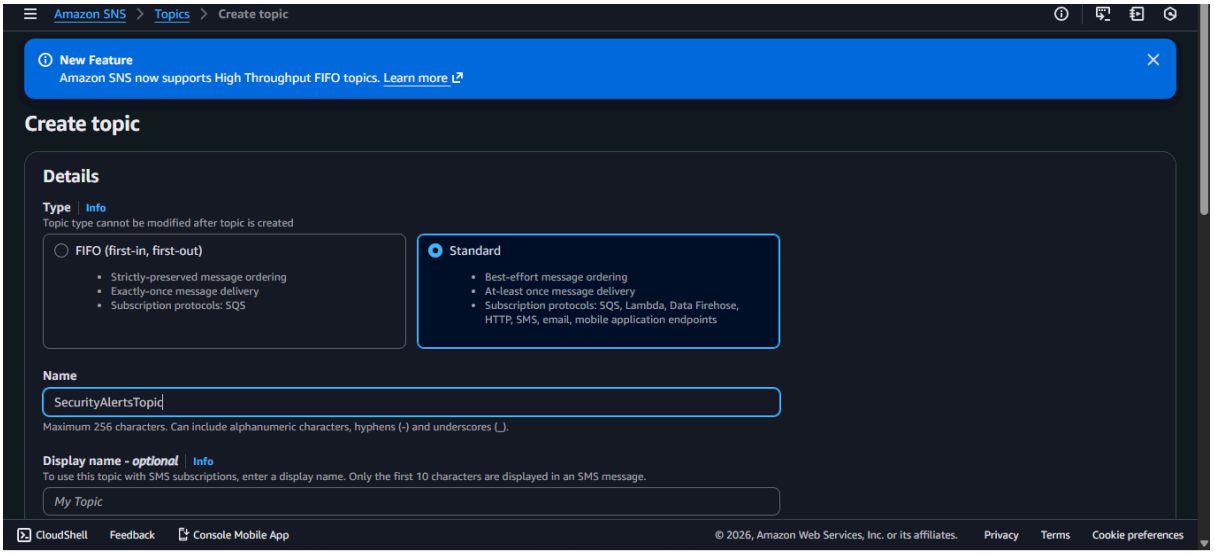
This component will be the communication channel that sends the alert email.

1. Go to the SNS (Simple Notification Service) Console.

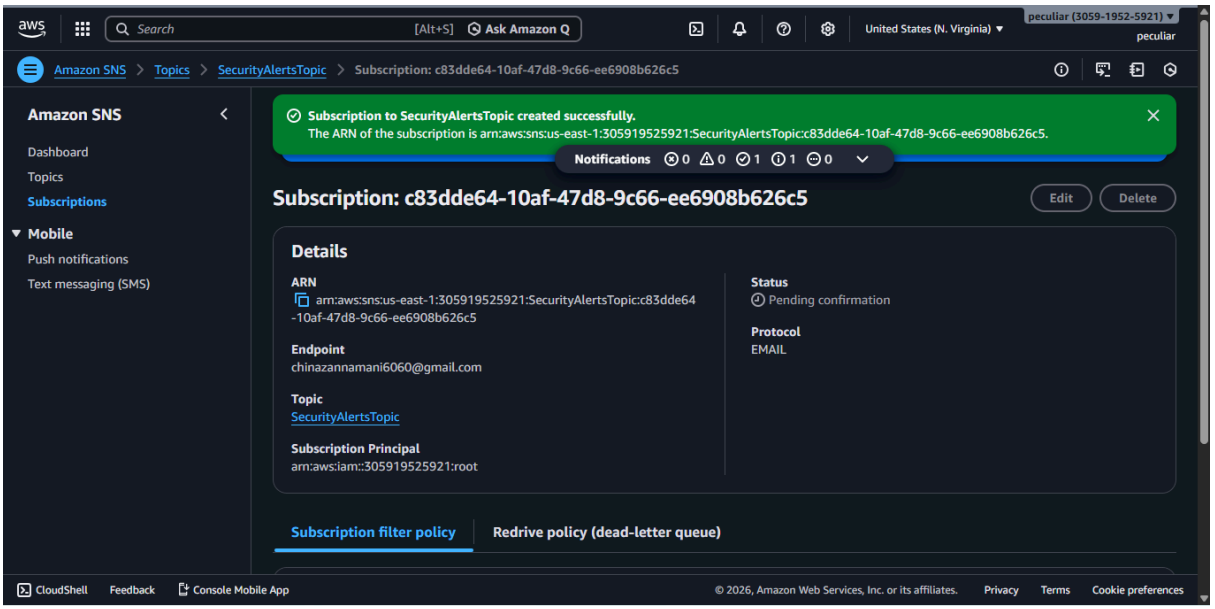


2. Create Topic:
   Click Topics > Create topic.

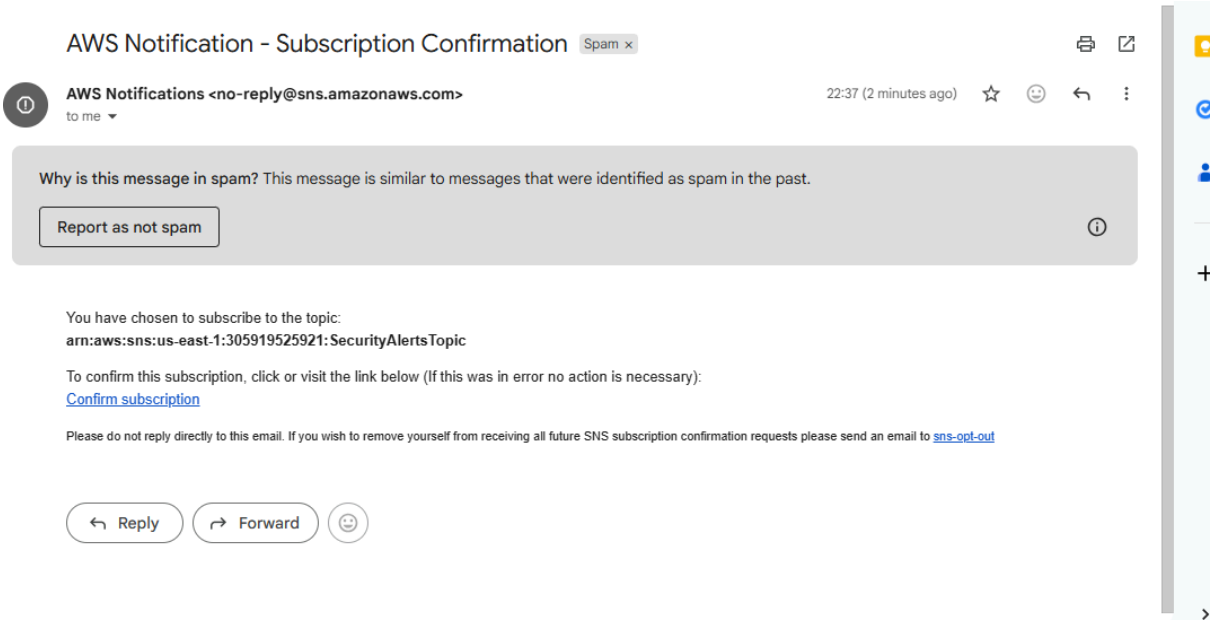
Select the Standard type.
Name it: SecurityAlertsTopic.

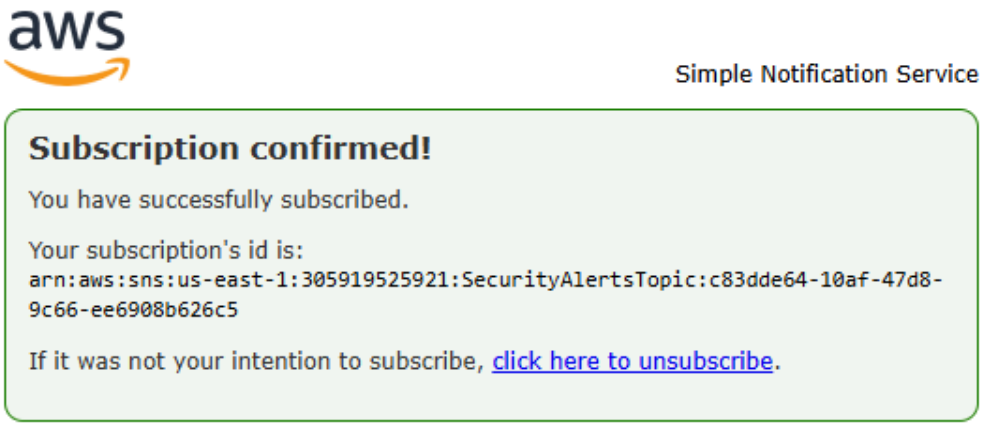


3. Create Subscription (The Receiver):
   - Inside your new topic, click Create subscription.
   - Protocol: Select Email.
   - Endpoint: Enter your personal email address. chinazannamani6060@gmail.com
   - Click Create subscription.



4. Confirm Subscription
   - Check your email inbox (chinazannamani6060@gmail.com)
   - Open the email from AWS and click the "Confirm subscription" link.
   You must do this to receive alerts

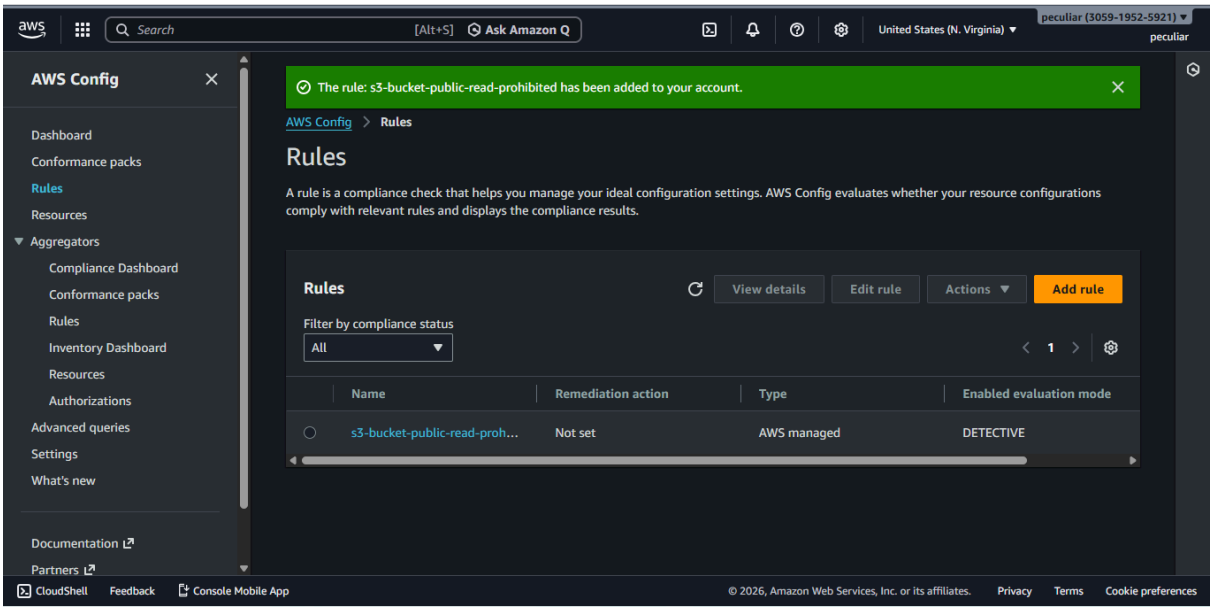




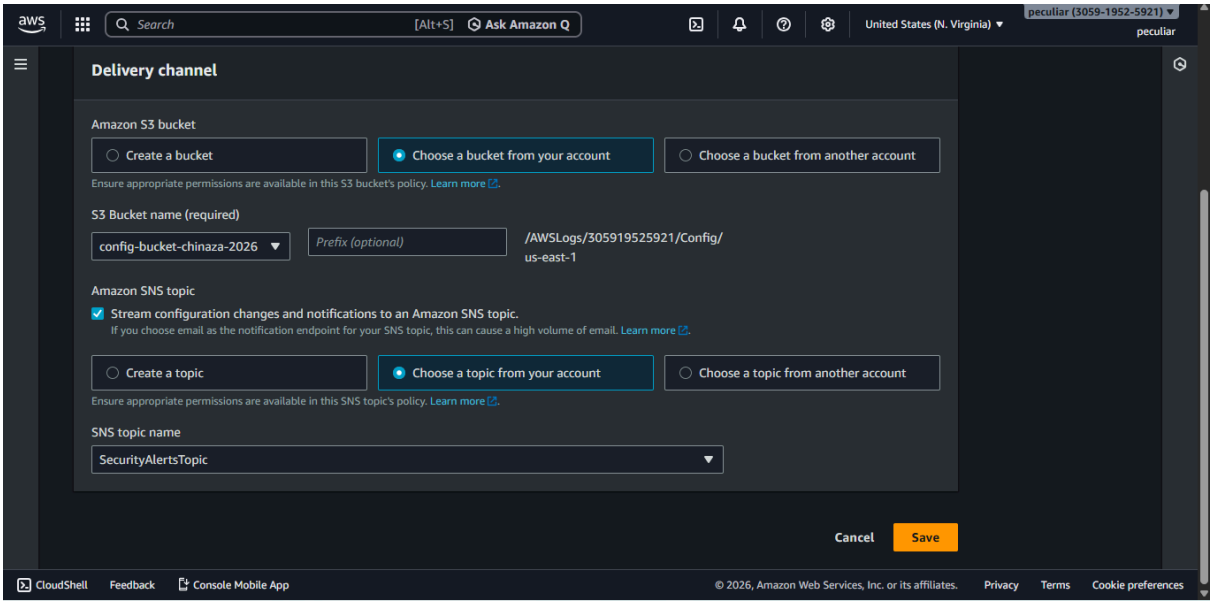
Part 3: Add the Compliance Rule and Link SNS

Now we define what "compliant" means and tell Config to use the SNS topic for alerts.

1. Add the Rule:
   - In the AWS Config console, go to Rules > Add rule.
   - Search for and select the AWS Managed Rule: s3-bucket-public-read-prohibited.
   - Accept the default settings and save the rule.



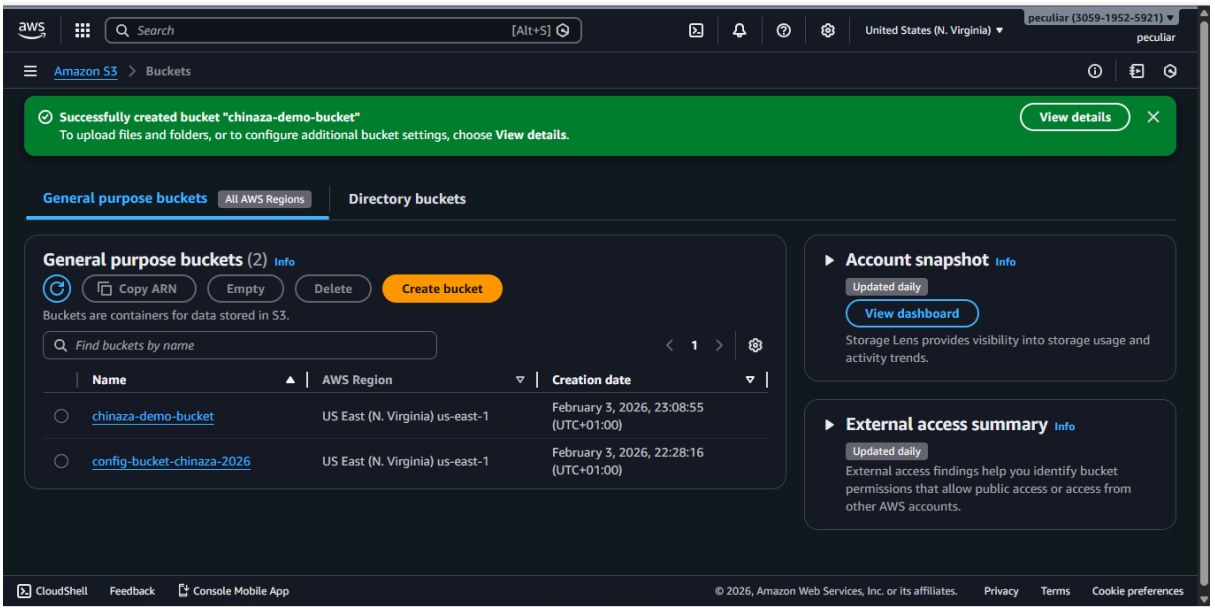
2. Link Config to SNS:
   - Go back to AWS Config Settings.
   - Find the section for the Delivery Channel.
   - You need to configure the delivery channel to stream notifications to the SNS topic. Select the SecurityAlertsTopic you created in Part 2.
   - Save the settings



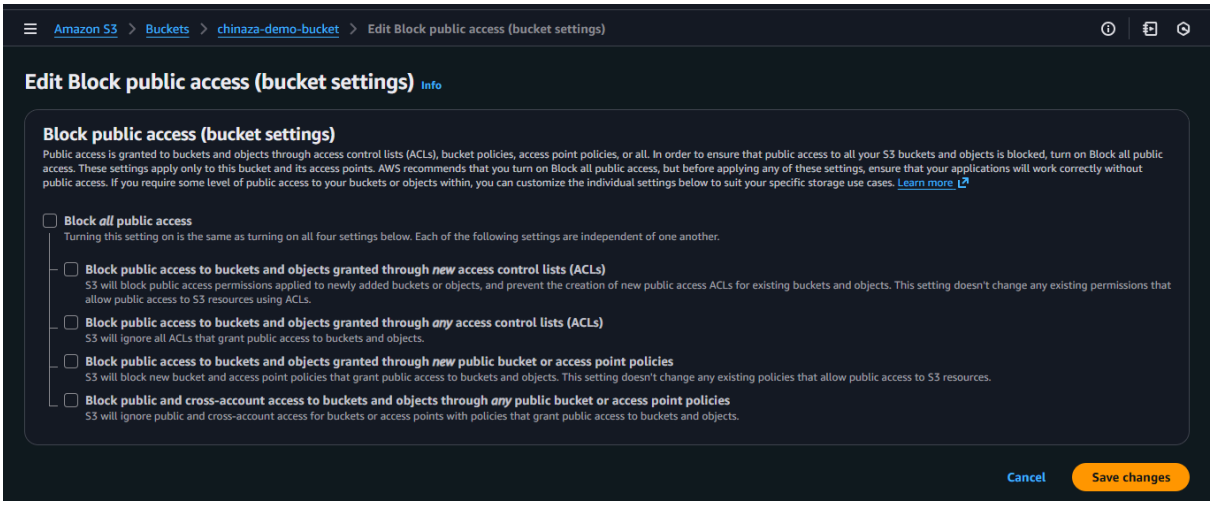
Part 4: The Break and Fix Cycle (The Test)

You will intentionally make a resource non-compliant to test the entire alert chain.

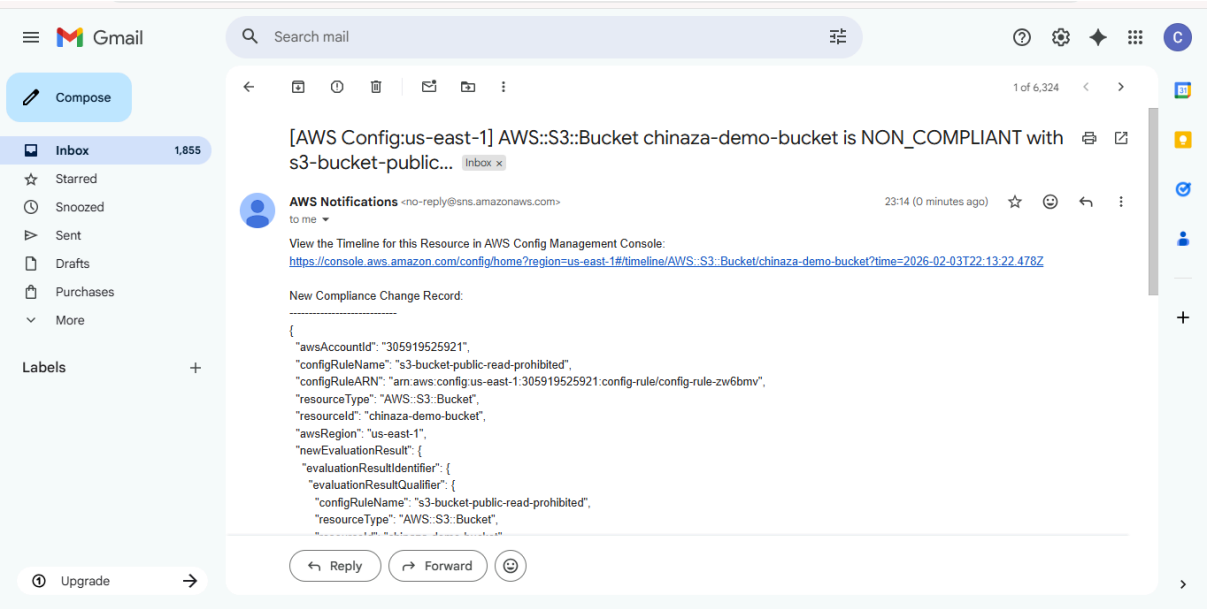
1. Create a Test S3 (chinaza-demo-bucket)
   Bucket: Go to the S3 console, create a new bucket.



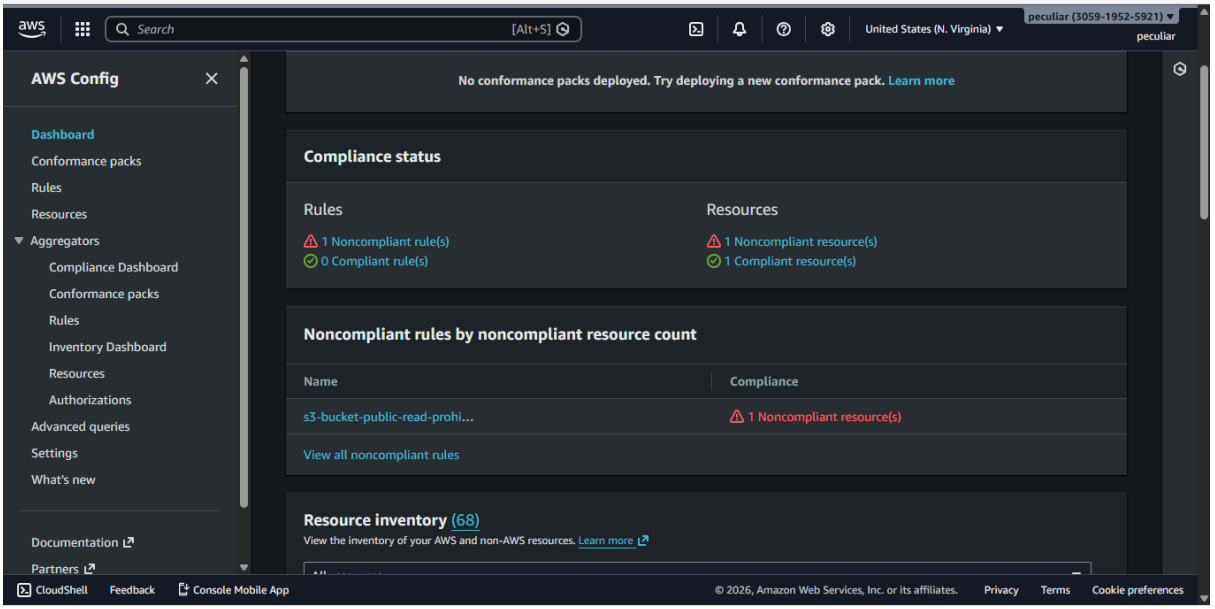
2. Intentionally change its permissions to make it publicly accessible



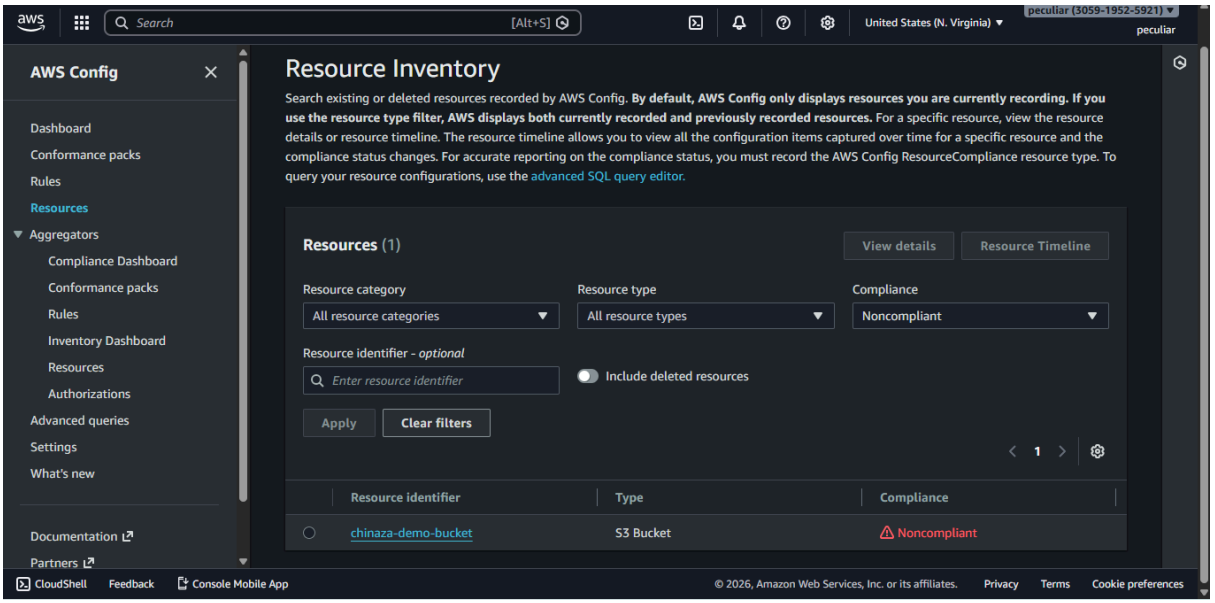
3. Check your Email: Wait for the alert to arrive in your personal inbox. The email will confirm the rule is non-compliant.



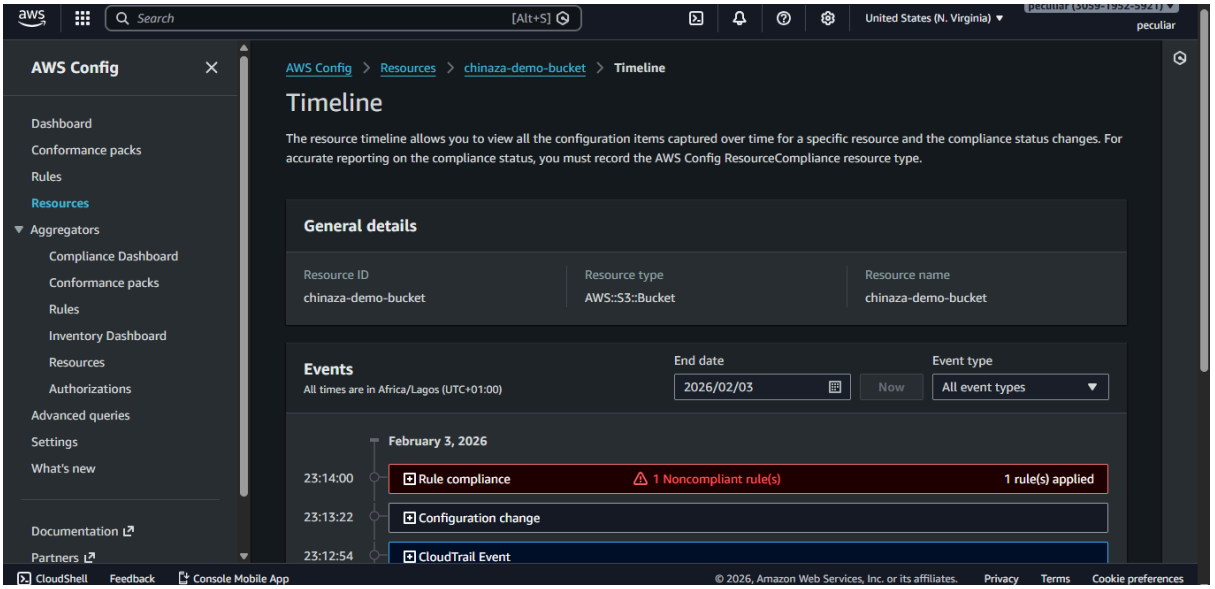
4. The new rule should be active. After a few minutes, the AWS Config Dashboard should show the s3-bucket-public-read-prohibited rule turning RED (Non-compliant)



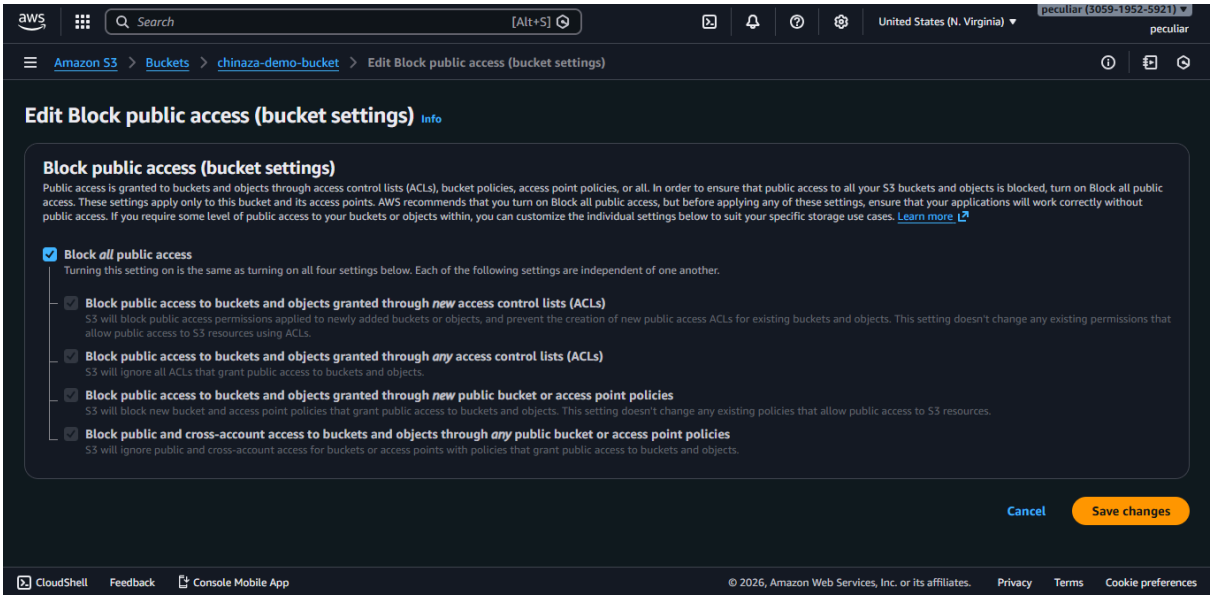
5. View the Timeline: Go back to AWS Config, navigate to Resource inventory, find your test S3 bucket, and click on Resource timeline.



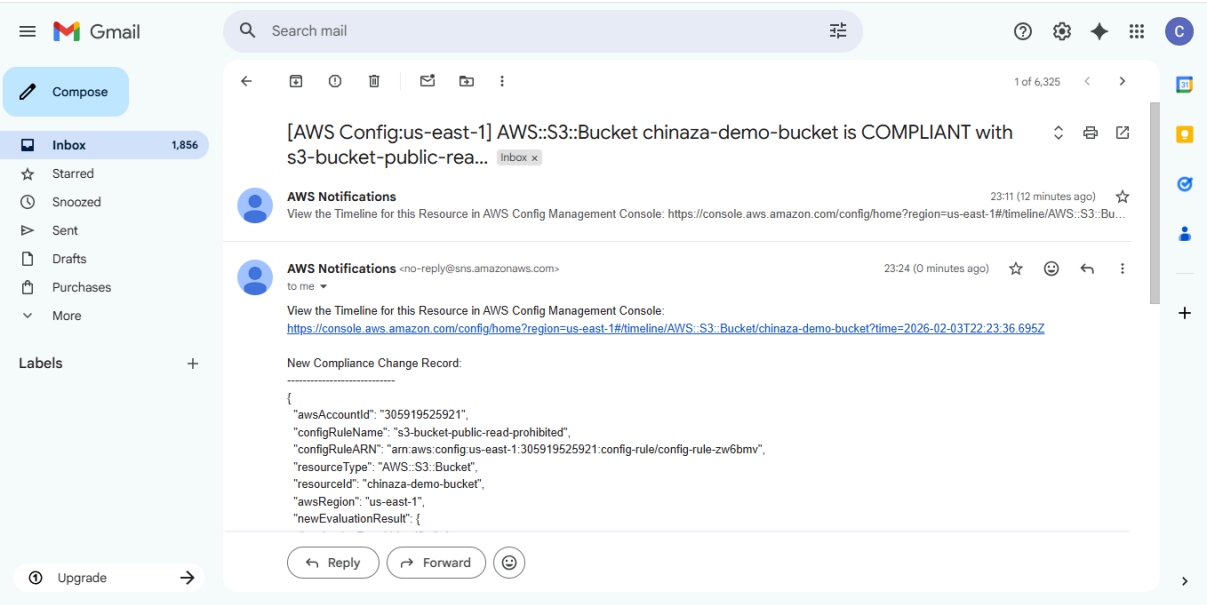
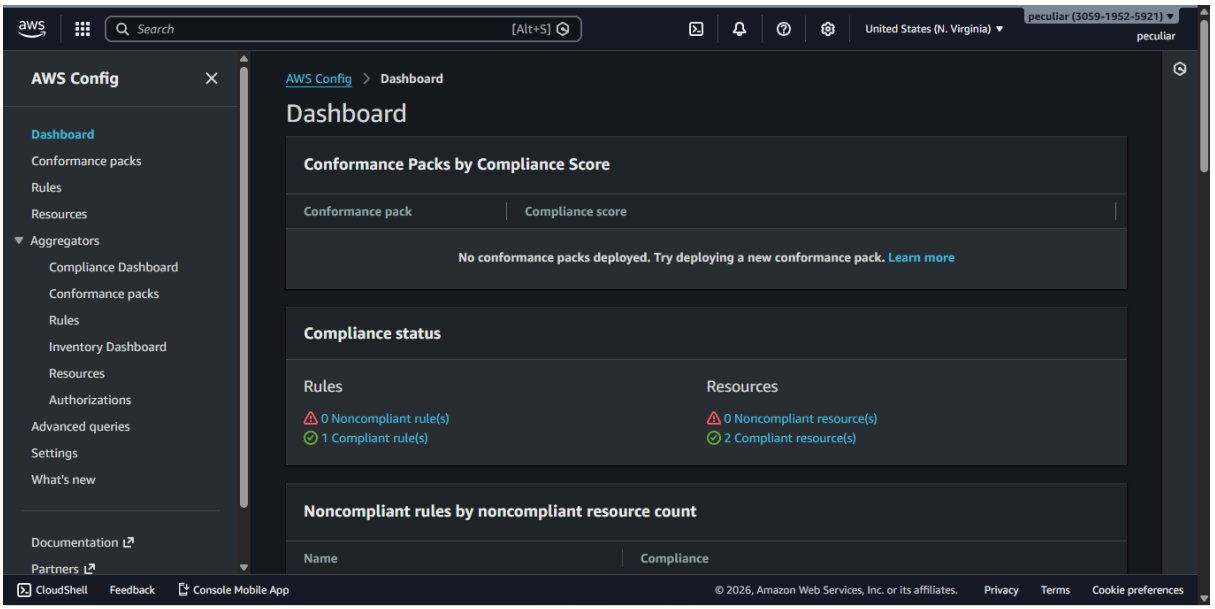
6. You can see the exact time and configuration change that made the bucket public.



7. To Fix the Resource: Go back to your test S3 bucket in the S3 console and change its permissions back to private.



8. You will receive an email alert confirming the resource is compliant



9. After a few more minutes, the AWS Config Dashboard should return to GREEN (Compliant).